

Incident and Response Lab 4: Excessive Resource Creation or Deletion

Explanation

This query is used to monitor and identify potential security or operational risks in an Azure environment by flagging high-volume resource creation or deletion activities. A high number of such operations can indicate unusual behavior, such as unauthorized access, automation misconfigurations, or even malicious activity. By pinpointing Callers performing 10 or more successful resource writes or deletions, this query helps administrators quickly focus on entities that may require further investigation or corrective action, enhancing overall security posture and operational governance.

Whenever a user or service performs resource creation or deletion activities in **Azure**, the corresponding logs are captured in the "**AzureActivity**" table, which is forwarded to the **Log Analytics Workspace** utilized by **Microsoft Sentinel**, our **SIEM**. Within Sentinel, we will define an alert to trigger when a Caller performs 10 or more successful resource creation ("WRITE") or deletion ("DELETE") operations. While not all alerts may represent true positives, this provides an opportunity to investigate potential unauthorized access, automation misconfigurations, or unusual activity patterns, ensuring better governance and security oversight of our Azure environment.

In order to generate the necessary logs for you to detect this activity, simply re-create a VM and delete it (and its accompanying resources) several times. It's possible this alert will already be able to trigger based on existing logs.

Part 1: Create Alert Rule (Excessive Resource Creation or Deletion)

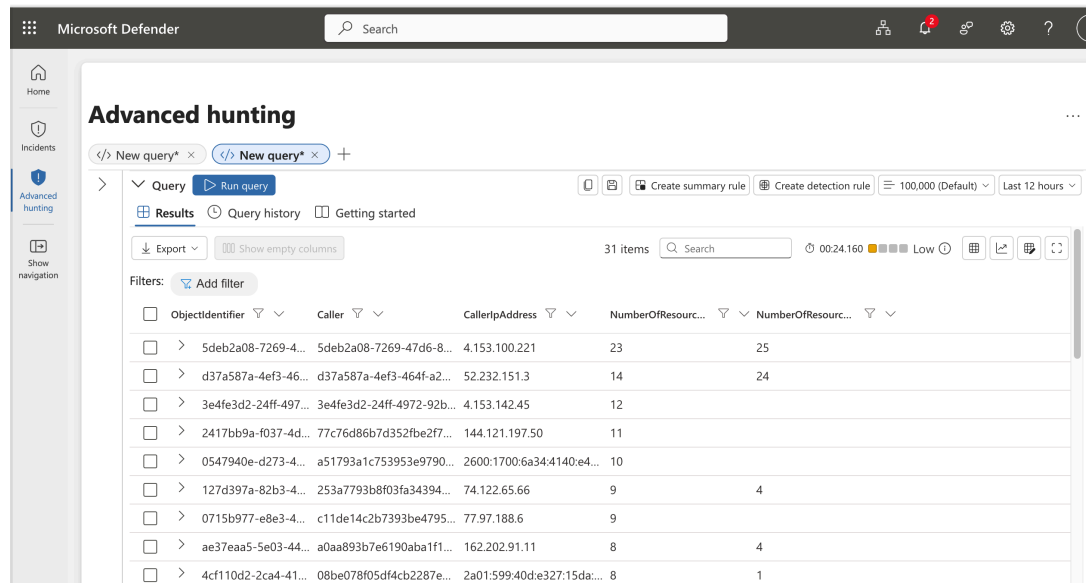
Please create a query that identifies users or entities (Callers) who have performed **5** or more successful resource creation ("WRITE") or deletion ("DELETE") operations in Azure, highlighting potential unusual or risky activity. Exclude any writing or deleting of incidents and alert rules

```
let ResourceCreations = AzureActivity
| extend ClaimsJson = parse_json(Claims)
| extend ObjectIdentifier = tostring(ClaimsJson["http://schemas.microsoft.com/identity/claims/objectidentifier"])
| where OperationNameValue !startswith "MICROSOFT.SECURITYINSIGHTS/ALERTRULES" and OperationNameValue !startswith "MICROSOFT.SECURITYINSIGHTS/INCIDENTS"
| where OperationNameValue endswith "WRITE" and ActivityStatusValue == "Success"
| summarize NumberOfResourceCreations = count() by Caller, ObjectIdentifier,
```

```

CallerIpAddress;
let ResourceDeletions = AzureActivity
| extend ClaimsJson = parse_json(Claims)
| extend ObjectIdentifier = tostring(ClaimsJson["http://schemas.microsoft.com/identity/claims/objectidentifier"])
| where OperationNameValue !startswith "MICROSOFT.SECURITYINSIGHTS/ALERTRULES" and OperationNameValue !startswith "MICROSOFT.SECURITYINSIGHTS/INCIDENTS"
| where OperationNameValue endswith "DELETE" and ActivityStatusValue == "Success"
| summarize NumberOfResourceDeletions = count() by Caller, ObjectIdentifier, CallerIpAddress;
ResourceCreations
| join kind=fullouter ResourceDeletions on ObjectIdentifier, Caller, CallerIpAddress
| project
    ObjectIdentifier,
    Caller,
    CallerIpAddress,
    NumberOfResourceCreations,
    NumberOfResourceDeletions
| where NumberOfResourceCreations >= 5 or NumberOfResourceDeletions >= 5
| order by NumberOfResourceCreations, NumberOfResourceDeletions,
    NumberOfResourceDeletions

```



The screenshot shows the Microsoft Defender Advanced Hunting interface. The query results are displayed in a table with the following columns: ObjectIdentifier, Caller, CallerIpAddress, NumberOfResourceCreations, and NumberOfResourceDeletions. The table contains 31 items, with the first 10 items shown in the screenshot. The interface also includes a search bar, a filter button, and a table view icon.

ObjectIdentifier	Caller	CallerIpAddress	NumberOfResourceCreations	NumberOfResourceDeletions
5deb2a08-7269-4...	5deb2a08-7269-47d6-8...	4.153.100.221	23	25
d37a587a-4ef3-46...	d37a587a-4ef3-464f-a2...	52.232.151.3	14	24
3e4fe3d2-24ff-497...	3e4fe3d2-24ff-4972-92b...	4.153.142.45	12	
2417bb9a-f037-4d...	77c76d86b7d352fbc2f7...	144.121.197.50	11	
0547940e-d273-4...	a51793a1c753953e9790...	2600:1700:6a34:4140:e4...	10	
127d397a-82b3-4...	253a7793b8f03fa34394...	74.122.65.66	9	4
0715b977-e8e3-4...	c11de14c2b7393be4795...	77.97.188.6	9	
ae37ea5-5e03-44...	a0aa893b7e6190aba1f1...	162.202.91.11	8	4
4cf110d2-2ca4-41...	08be078f05df4cb2287e...	2a01:599:40de327:15da...	8	1

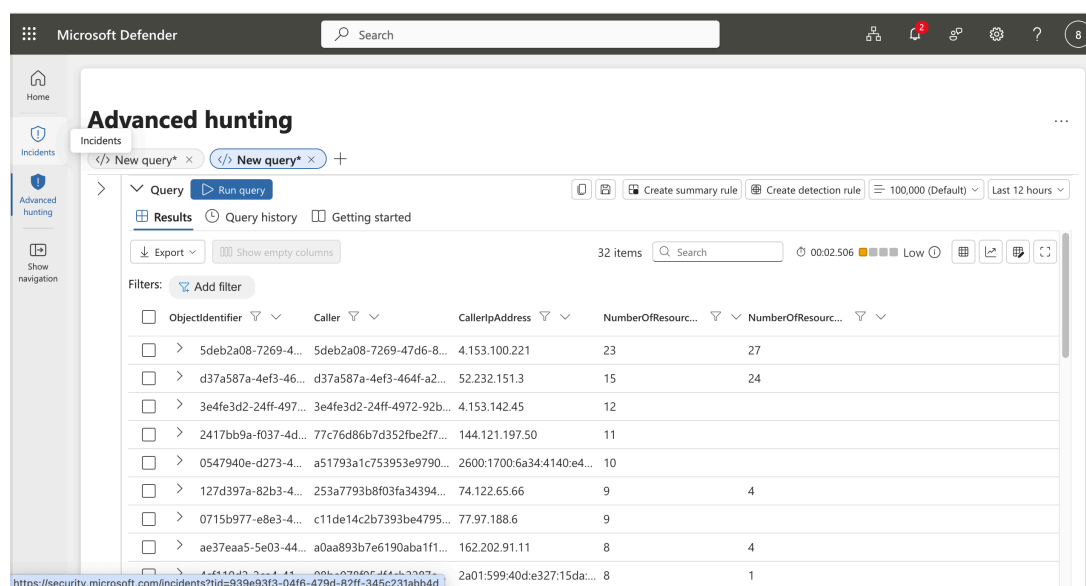
Once your query is good, create the Schedule Query Rule in: **Sentinel** → **Analytics** → **Schedule Query Rule**

Analytics Rule Settings:

- Name:
- Description:
- Enable the Rule
- Use ChatGPT to set Mitre ATT&CK Framework Categories based on the query:
 - **Technique: Data Destruction (T1485)**
 - **Technique: Resource Hijacking (T1496)**
- Run query every **4 hours**
- Lookup data for last **7 days** (up to you though)
- Stop running query after alert is generated == Yes
- Configure Entity Mappings:
 - Account
 - ◆ Identifier: Sid, Value: ObjectIdentifier
 - IP
 - ◆ Identifier: Address, Value: CallerIpAddress
- Automatically create an Incident if the rule is triggered
- Group all alerts into a single Incident per 24 hours
- Stop running query after alert is generated (24 hours)

Part 2: Trigger Alert to Create Incident

Reminder: In order to generate the necessary logs for you to detect this activity, simply re-create a VM and delete it (and its accompanying resources) several times. **It's possible this alert will already be able to trigger based on existing logs from other users. Therefore:**



The screenshot shows the Microsoft Defender Advanced Hunting interface. The 'Query' tab is active, displaying a table with 32 items. The table has columns for ObjectIdentifier, Caller, CallerIpAddress, and NumberOfResources. The data is filtered by 'Last 12 hours' and '100,000 (Default)' items.

ObjectIdentifier	Caller	CallerIpAddress	NumberOfResources
5deb2a08-7269-4...	5deb2a08-7269-47d6-8...	4.153.100.221	23
d37a587a-4ef3-46...	d37a587a-4ef3-464f-a2...	52.232.151.3	15
3e4fe3d2-24ff-497...	3e4fe3d2-24ff-4972-92b...	4.153.142.45	12
2417bb9a-f037-4d...	77c76d86b7d352f2f7...	144.121.197.50	11
0547940e-d273-4...	a51793a1c753953e9790...	2600:1700:6a34:4140:e4...	10
127d397a-82b3-4...	253a7793b8f03fa34394...	74.122.65.66	9
0715b977-e8e3-4...	c11de14c2b7393be4795...	77.97.188.6	9
ae37ea5-5e03-44...	a0aa893b7e6190aba1f1...	162.202.91.11	8
...	...	...	...

Don't get confused between the [Configuration → Analytics] and [Threat

Management → Incidents] sections.

Part 3: Work Incident

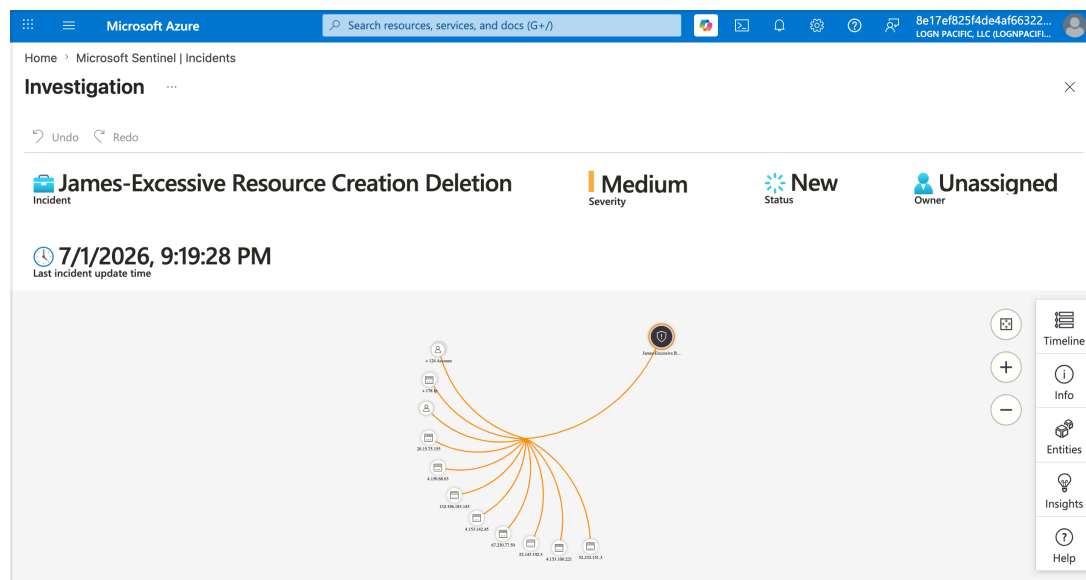
Work your incident to completion and close it out, in accordance with the NIST 800-161: Incident Response Lifecycle

Preparation

- Document roles, responsibilities, and procedures.
- Ensure tools, systems, and training are in place.

Detection and Analysis

- Identify and validate the incident.
 - Observe the incident and assign it to yourself, set the status to Active
 - Investigate the Incident by **Actions** → **Investigate** (sometimes takes time for entities to appear)



- Gather relevant evidence and assess impact.
 - Take note of any associated accounts and if they were involved in any other incidents
 - Investigate each individual account using a KQL query within Log Analytics to see exactly what they have been creating or deleting. Take note if it looks different from unusual behavior. This could be *literally anything*.

// Put your long username here, or any other user you want to track

let UserInQuestion =

"77c76d86b7d352fbe2f71ad1d55d1b2df0c05b7d9621e8dc8d345d6e9b9e56c7@lognpacific.com";

AzureActivity

| where Caller contains UserInQuestion

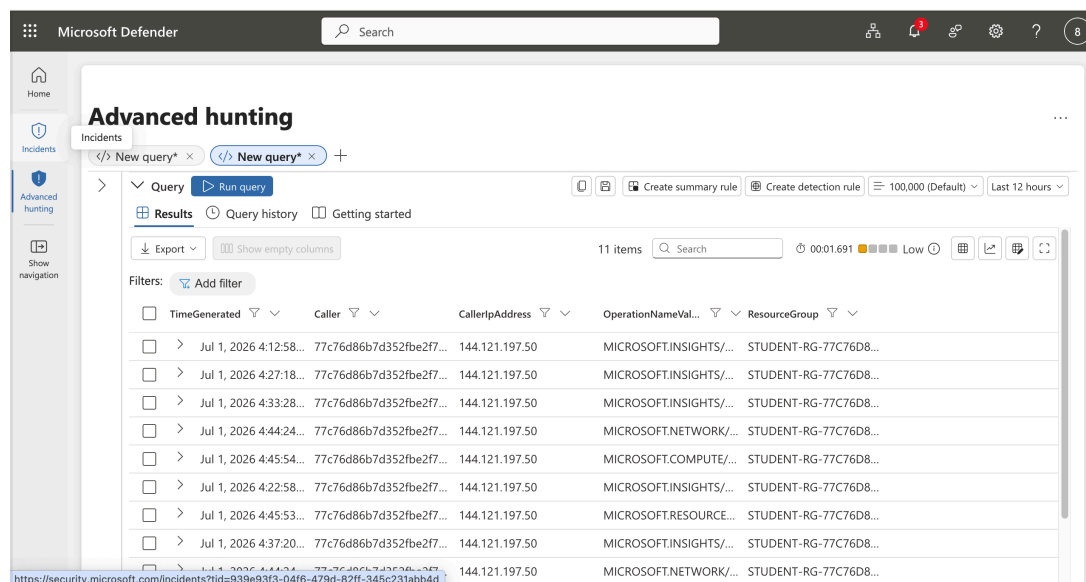
| where OperationNameValue !startswith "MICROSOFT.SECURITYINSIGHTS/ALERTRULES" and OperationNameValue !startswith

"MICROSOFT.SECURITYINSIGHTS/INCIDENTS"

| where OperationNameValue endswith "WRITE" or OperationNameValue endswith "DELETE"

| where ActivityStatusValue == "Success"

| project TimeGenerated, Caller, CallerIpAddress, OperationNameValue, ResourceGroup



Containment, Eradication, and Recovery

- Isolate affected systems to prevent further damage.
 - In real life, depending on corporate policy and evidence, you might immediately disable the account in Entra ID (Azure Active Directory) and contact yours or the user's manager.
 - Put in your notes (either or):
 - ♦ **TRUE POSITIVE:** The alert has been confirmed as a true positive. Investigation revealed that the user "77c76d86b7d352fbe2f71ad1d55d1b2df0c05b7d9621e8dc8d345d6e9b9e56c7@lognpacific.com" was creating an excessive number of virtual machines in an unusual pattern. This activity deviates from typical usage behavior and may indicate unauthorized or malicious intent, such as resource abuse, unauthorized automation, or a compromised account. Immediate

steps should be taken to assess the user's access permissions, audit recent activities, and mitigate any potential risks to the environment.

- ◆ **FALSE POSITIVE:** The alert has been reviewed and determined to be a false positive. The user "77c76d86b7d352fbe2f71ad1d55d1b2df0c05b7d9621e8dc8d345d6e9b9e56c7@lognpacific.com" was found to be creating multiple virtual machines as part of a legitimate activity. The behavior aligns with their role and responsibilities, such as provisioning resources for a project or scaling an application. No malicious intent or unauthorized activity was identified. However, it is recommended to continue monitoring to ensure consistent alignment with organizational policies and resource usage guidelines.
- Remove the threat and restore systems to normal.
 - Remove the threat by disabling the users account and escalating to management. If found to be a false positive, simply document it
 - **TRUE POSITIVE:** The user's account was disabled and management contacted.
 - **FALSE POSITIVE:** Management has verified the activities to be related to a routine exercise

Post-Incident Activities

- Document findings and lessons learned.
 - Record your notes within the incident.
- Update policies and tools to prevent recurrence.
 - You could potentially make use of Azure Resource Graph or Azure Policy to restrict resource creation in some way, but this might just be one of these things where you'll have to just investigate the alerts as they come up, or tune the rule if there are too many alerts.

Closure

- Review and confirm incident resolution.
 - Review/observe your notes for the incident.
- Finalize reporting and close the case.
 - Close out the Incident within Sentinel as a "True Positive" (or whatever it was in your case)

Part 4: Cleanup (BE EXTREMELY CAREFUL HERE)

In Sentinel → Threat Management → Incidents, filter for closed incidents and delete YOUR incident

In Sentinel → Configuration → Analytics, delete YOUR analytics rule.

Be extremely careful to only delete YOUR Incident and Analytics Rule. Do not screw this up and delete someone else's, because it's possible. **Search by your name to narrow them down if you have to.**